



Security Scan Report

■■■■	2026-04-02
■■■■	PornActressDB-Golang-Migration
Python ■■	75 ■
Go ■■	16 ■■■■■■■■
■■■■	91 ■
■■■■	Bandit 1.9.4 (Python) Go ■■■■■■■■ (Go) gosec - ■■■■ semgrep - ■■■■
■■■■	Go/gosec/semgrep ■■■■■■■■■■Go ■■■■■■■■■■



■■■■■■■ PornActressDB-Golang-Migration ■■■■ 91 ■■■■■■■■75 ■ Python + 16 ■ Go■■■■■■■■■■■■■■■■■■■■ 29
■■■■■■■■Python: 14 ■■Go ■■■■■: 15 ■■■■

■■■■	■■■■	■■
CRITICAL (■■■)	0	■■■■■■■■■■■■■■■■■■■■
HIGH (■)	2	■■■■■■■■■■■■■■■■■■■■
MEDIUM (■)	11	■■■■■■■■■■■■■■■■■■■■
LOW (■)	16	■■■■■■■■■■■■■■■■■■■■
■■■	29	■■■■■■■■■■



■■■■ (HIGH) — 2 ■■■■

[c4794f91be8e] TOCTOU Race Condition - File Overwrite Risk

■■	pkg/mover/mover.go ■ 152
■■	Go ■■■■■
CWE	CWE-367
■■	Check if destination exists then perform operations. Between check and operation, destination could be created/modified by another process.
■■	Use atomic file operations with O_EXCL flag or file locking. Avoid separate stat/rename calls.

[f58e3986b77f] Unsafe Batch File Deletion - Data Loss Risk

■■	pkg/mover/mover.go ■ 272
■■	Go ■■■■■
CWE	CWE-662
■■	os.RemoveAll(src) is called after batch operations. If some files failed but result shows success, RemoveAll could delete files that were not intended for deletion.
■■	Only delete source if ALL files successfully moved. Track which files actually moved to prevent deleting unprocessed files.

■■■■ (MEDIUM) — 11 ■■■■

[a005c3df722b] Insufficient Path Validation

■■	cmd/scanner/main.go ■ 109
■■	Go ■■■■■
CWE	CWE-22
■■	Directory path from user input is passed to filepath.WalkDir without proper validation. No verification that the resolved absolute path is within the intended directory.
■■	Use filepath.Join and filepath.Rel to verify the resolved absolute path stays within the intended directory.

[d74587ee7445] Unsafe JSON Deserialization

■■	cmd/scanner/main.go ■ 246
■■	Go ■■■■■
CWE	CWE-502
■■	User-supplied JSON from batch file is unmarshalled directly without schema validation or size limits, potentially allowing large allocations and memory exhaustion.
■■	Implement size limits on JSON input (use io.LimitReader), validate field types explicitly.

[2890852b89c8] TOCTOU Race Condition

■■	pkg/cache/cache.go ■ 79
■■	Go ■■■■■
CWE	CWE-367
■■	os.Rename operation is not atomic at application level. Between checking file existence and performing rename, another process could create or modify the file.
■■	Use atomic file operations; write to temp file, then use os.Rename which is atomic on most filesystems.

[273bdc76b86b] Unsafe JSON Deserialization

■■	pkg/database/sqlite.go ■ 110
■■	Go ■■■■■
CWE	CWE-502
■■	Large JSON database files are unmarshalled without size validation. This could cause memory exhaustion if attacker controls the c
■■	Implement size limits on file reads. For large files, use json.Decoder with streaming approach.

[0f12b1b369d9] TOCTOU Race Condition

■■	pkg/database/sqlite.go ■ 239
■■	Go ■■■■■
CWE	CWE-367
■■	Write to tmp file + os.Rename sequence has a potential race window where data loss could occur if process crashes between open
■■	Implement file locking (fcntl/flock) around the entire write-rename sequence.

[f096ffd01aac] Unsafe JSON Deserialization

■■	pkg/database/sqlite.go ■ 29
■■	Go ■■■■■
CWE	CWE-502
■■	Journal entries are unmarshalled line-by-line without size validation. Malicious journal entries could cause memory exhaustion.
■■	Add maximum line length validation before json.Unmarshal. Use bufio.Scanner.Buffer() to limit line sizes.

[aaab95fe6b46] Incomplete File Operation Recovery

■■	pkg/mover/mover.go ■ 195
■■	Go ■■■■■
CWE	CWE-662
■■	If copyFile succeeds but os.Remove(src) fails, file is duplicated but error is returned. Caller does not know source still exists, poten
■■	Implement transaction-style rollback: if Remove fails, remove the copied dst and return error.

[8a7e41e222bf] Path Traversal Risk

■■	pkg/mover/mover.go ■ 238
■■	Go ■■■■■
CWE	CWE-22
■■	filepath.Walk traverses user-supplied path without validation. Symlinks in the source directory could lead to operations outside inter
■■	Before walking, resolve source path to absolute and verify it does not contain symlinks to parent directories.

[a331bca847a4] Predictable Temporary File

■■	pkg/mover/mover.go ■ 548
■■	Go ■■■■■
CWE	CWE-377
■■	Temporary file name uses time.Now().UnixNano() for uniqueness, but in high-concurrency scenarios two processes could generate
■■	Use os.CreateTemp instead of manual naming. It uses cryptographically secure randomness.

[bb9a8b9ca6a3] File Handle Resource Leak

■■	pkg/safefile/safefile.go ■ 59
■■	Go ■■■■■

CWE	CWE-775
■■	root.Open(name) returns a file handle but the file is never closed in OpenRead function. Caller must close it, but if caller forgets, file
■■	Document that caller must close the returned file. Consider returning only data (bytes) rather than file handles.

[57912a308cf8] Unsafe JSON Deserialization

■■	pkg/studio/identifier.go ■ 148
■■	Go ■■■■
CWE	CWE-502
■■	Studios.json is unmarshalled without size validation. Malicious JSON could cause memory exhaustion.
■■	Add file size limits before reading. Use json.Decoder with streaming for large files.

■■■ (LOW) — 16 ■■■

[668ec2c28b1d] B110

■■	run.py ■ 15
■■	Bandit (Python)
CWE	CWE-703
■■	Try, Except, Pass detected.
■■	Review and fix B110 issue. See: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html

[4de3235b369a] B311

■■	src/scrapers/base_scraper.py ■ 117
■■	Bandit (Python)
CWE	CWE-330
■■	Standard pseudo-random generators are not suitable for security/cryptographic purposes.
■■	Review and fix B311 issue. See: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random

[3e62e020319d] B311

■■	src/scrapers/enhanced/encoding_handler.py ■ 164
■■	Bandit (Python)
CWE	CWE-330
■■	Standard pseudo-random generators are not suitable for security/cryptographic purposes.
■■	Review and fix B311 issue. See: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random

[f1ecb9c5682a] B311

■■	src/scrapers/rate_limiter.py ■ 111
■■	Bandit (Python)
CWE	CWE-330
■■	Standard pseudo-random generators are not suitable for security/cryptographic purposes.
■■	Review and fix B311 issue. See: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random

[dcabe50bd8fe] B110

■■	src/scrapers/sources/javadb_scraper.py ■ 282
----	--

■■	Bandit (Python)
CWE	CWE-703
■■	Try, Except, Pass detected.
■■	Review and fix B110 issue. See: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html

[080513dfbf67] B110

■■	src/services/classifier_core.py ■ 452
■■	Bandit (Python)
CWE	CWE-703
■■	Try, Except, Pass detected.
■■	Review and fix B110 issue. See: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html

[2a4efd35e254] B404

■■	src/services/go_bridge.py ■ 37
■■	Bandit (Python)
CWE	CWE-78
■■	Consider possible security implications associated with the subprocess module.
■■	Review and fix B404 issue. See: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b404-import-subprocess

[ad85333af0f9] B603

■■	src/services/go_bridge.py ■ 192
■■	Bandit (Python)
CWE	CWE-78
■■	subprocess call - check for execution of untrusted input.
■■	Review and fix B603 issue. See: https://bandit.readthedocs.io/en/1.9.4/plugins/b603_subprocess_without_shell_equals_true.html

[3b3a30b40d8c] B603

■■	src/services/go_bridge.py ■ 239
■■	Bandit (Python)
CWE	CWE-78
■■	subprocess call - check for execution of untrusted input.
■■	Review and fix B603 issue. See: https://bandit.readthedocs.io/en/1.9.4/plugins/b603_subprocess_without_shell_equals_true.html

[cc68c162121c] B110

■■	src/services/unified_cache.py ■ 60
■■	Bandit (Python)
CWE	CWE-703
■■	Try, Except, Pass detected.
■■	Review and fix B110 issue. See: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html

[3db79ee68583] B311

■■	src/utils/retry_utils.py ■ 56
■■	Bandit (Python)
CWE	CWE-330

■■	Standard pseudo-random generators are not suitable for security/cryptographic purposes.
■■	Review and fix B311 issue. See: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random

[bc35a1bed8c9] B403

■■	tests/test_cache_manager_security.py ■ 7
■■	Bandit (Python)
CWE	CWE-502
■■	Consider possible security implications associated with pickle module.
■■	Review and fix B403 issue. See: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b403-import-pickle

[70ebb0e58472] B404

■■	tools/integration/go_integration.py ■ 7
■■	Bandit (Python)
CWE	CWE-78
■■	Consider possible security implications associated with the subprocess module.
■■	Review and fix B404 issue. See: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b404-import-subprocess

[20fce18ac0fb] B603

■■	tools/integration/go_integration.py ■ 22
■■	Bandit (Python)
CWE	CWE-78
■■	subprocess call - check for execution of untrusted input.
■■	Review and fix B603 issue. See: https://bandit.readthedocs.io/en/1.9.4/plugins/b603_subprocess_without_shell_equals_true.html

[2484cbf1b59e] Predictable Temporary File

■■	pkg/database/jsondb.go ■ 232
■■	Go ■■■■■
CWE	CWE-377
■■	Temporary files created with predictable pattern 'dataFile + .tmp'. If multiple processes write simultaneously, collisions could occur.
■■	Use os.CreateTemp to generate cryptographically random temp filenames.

[1f4dfad8b3b7] Potential ReDoS

■■	pkg/extractor/extractor.go ■ 97
■■	Go ■■■■■
CWE	CWE-1333
■■	Regex patterns could match very long strings, potentially causing Regex Denial of Service in edge cases.
■■	Add string length limits before regex matching. Test regexes with very long inputs.



██████ | PornActressDB-Golang-Migration ██████████ | 2026-04-02 12:35 (UTC+8)